Barclays IT & Cybersecurity Governance Manual (2024)

Table of Contents

Policy 1: Information Security Policy

- **Purpose & Scope**
- **Governance & Accountability**
- **Data Classification & Handling**
- **Access Control**
- **Encryption Standards**
- **Monitoring & Logging**
- **Employee Responsibilities**
- **Compliance & Regulation**
- **Enforcement**

Policy 2: Cybersecurity Policy

- **Purpose & Scope**
- **Governance & Accountability**
- **Threat Detection & Monitoring**
- **Incident Response & Escalation**
- **Penetration Testing & Vulnerability Management**
- **Third-Party & Supply Chain Risk**
- **AI & Emerging Technology Risks**
- **Employee Awareness & Training**
- **Compliance & Regulation**
- **Metrics & KPIs**
- **Enforcement**

Policy 3: IT Operations & Resilience Policy

- **Purpose & Scope**
- **Governance & Accountability**
- **Business Continuity Management (BCM)**
- **Disaster Recovery (DR)**
- **Change Management**
- **Cloud Security & Resilience**
- **Resilience Testing**
- **Operational KPIs**
- **Third-Party & Outsourcing Risk**
- **Compliance & Regulation**
- **Continuous Improvement**

Policy 4: Data Privacy & Compliance Policy

- **Purpose & Scope**
- **Governance & Accountability**
- **Data Collection & Processing**
- **Data Subject Rights**
- **Data Security & Protection**
- **Data Retention & Disposal**
- **Third-Party & Vendor Compliance**
- **Employee Responsibilities**
- **Breach Management**
- **Compliance & Regulation**
- **Metrics & KPIs**
- **Enforcement**

Policy 5: Employee & Insider Risk Policy

- **Purpose & Scope**
- **Governance & Accountability**
- **Employee Onboarding & Screening**
- **Acceptable Use Policy**
- **Monitoring & Detection**
- **Training & Awareness**
- **Incident Response & Escalation**
- **Whistleblowing & Reporting**
- **Third-Party & Contractor Risk**
- **Compliance & Regulation**
- **Metrics & KPIs**
- **Enforcement**

Policy 6: Emerging Technology & AI Policy

- **Purpose & Scope**
- **Governance & Accountability**
- **AI Governance Framework**
- **Security & Risk Management**
- **Emerging Technology Adoption**
- **Regulatory Compliance**
- **Employee Awareness & Training**
- **Metrics & KPIs**
- **Continuous Improvement**
- **Enforcement**

Policy 7: Audit & Continuous Improvement Policy

- **Purpose & Scope**
- **Governance & Accountability**
- **Audit Framework**
- **Continuous Monitoring**
- **Continuous Improvement Cycle**
- **Incident & Breach Reviews**
- **Vendor & Third-Party Assurance**
- **Regulatory Compliance**
- **Employee Engagement**
- **Metrics & KPIs**
- **Enforcement**

Policy 1: Information Security Policy

1. Purpose & Scope

This policy defines Barclays' approach to protecting information assets, ensuring confidentiality, integrity, and availability (CIA). It applies to:

- All employees, contractors, and third-party vendors.
- All systems, applications, and data owned or processed by Barclays globally.
- All business units and subsidiaries.

2. Governance & Accountability

- **Board Oversight:** The Audit Committee reviews information security risks quarterly.
- **CISO Role:** Accountable for policy implementation, reporting to the Group Risk Committee.
- **Business Unit Responsibility:** Each unit must appoint an Information Security Officer (ISO).
- **Internal Audit:** Conducts annual reviews of compliance with this policy.

3. Data Classification & Handling

- **Classification Levels:**
  - Public: freely shareable.
  - Internal: restricted to Barclays staff.
  - Confidential: sensitive customer or financial data.
  - Highly Confidential: strategic, regulatory, or M&A data.
- **Handling Rules:**
  - Confidential/Highly Confidential data must be encrypted at rest and in transit.
  - Printing restricted; physical copies tracked.
  - Cloud storage requires Barclays-approved providers.
  - Data retention aligned with regulatory requirements (minimum 7 years for financial records).

4. Access Control

- **Principle of Least Privilege:** Access granted only to perform job duties.
- **Authentication:** MFA mandatory for all privileged accounts.
- **Periodic Review:** Quarterly access recertification by managers.
- **Privileged Access Management (PAM):** All admin accounts monitored via PAM tools.
- **Segregation of Duties:** No single user may initiate and approve critical transactions.

5. Encryption Standards

- **Data at Rest:** AES-256 encryption.
- **Data in Transit:** TLS 1.3 or higher.
- **Key Management:** Keys rotated annually; stored in Hardware Security Modules (HSMs).
- **Mobile Devices:** Encrypted storage with Barclays-approved Mobile Device Management (MDM).

6. Monitoring & Logging

- **Audit Logs:** Immutable, retained for 7 years.
- **SIEM Integration:** All critical systems feed into Barclays' Security Information and Event Management (SIEM).
- **Alerting:** SOC monitors anomalies 24/7.
- **User Activity Monitoring:** High-risk activities flagged for review.

7. Employee Responsibilities

- **Training:** Annual mandatory training with phishing simulations.
- **Reporting:** Employees must report suspected breaches within 1 hour.
- **Acceptable Use:** Personal devices allowed only under BYOD policy with MDM controls.
- **Password Policy:** Minimum 14 characters, rotated every 90 days.

8. Compliance & Regulation

- **GDPR & UK Data Protection Act:** Full compliance with data subject rights.
- **FCA/PRA Requirements:** Alignment with operational resilience frameworks.
- **NIS2 Directive (EU):** Applies to European operations.
- **PCI-DSS:** Compliance for payment card data.

9. Enforcement

- **Violations:** May result in disciplinary action, up to termination.
- **Audit:** Internal Audit reviews compliance annually.
- **Continuous Improvement:** Policy updated annually to reflect new threats.

Policy 2: Cybersecurity Policy

1. Purpose & Scope

This policy establishes Barclays' approach to managing cybersecurity risks, protecting customer and corporate data, and ensuring operational resilience against evolving threats. It applies to:

- All Barclays employees, contractors, and third-party vendors.
- All IT systems, applications, and networks globally.
- All business units and subsidiaries, including joint ventures.

2. Governance & Accountability

- **Board Oversight:** The Risk Committee and Audit Committee review cyber risk quarterly.
- **Chief Information Security Officer (CISO):** Accountable for cyber strategy, reporting to the Group Risk Committee.
- **Cybersecurity Steering Committee:** Cross-functional body overseeing implementation, chaired by the CISO.
- **Internal Audit:** Conducts independent reviews of cyber resilience annually.

3. Threat Detection & Monitoring

- **Security Operations Centre (SOC):** Operates 24/7 with global coverage.
- **SIEM Integration:** All critical systems feed into Barclays' Security Information and Event Management (SIEM).
- **Automated Threat Detection:** AI-driven analytics to identify anomalies, phishing attempts, and malware.
- **Threat Intelligence:** Barclays subscribes to global intelligence feeds (FS-ISAC, NCSC UK).
- **Continuous Monitoring:** Real-time monitoring of endpoints, servers, and cloud environments.

4. Incident Response & Escalation

- **Incident Response Plan (IRP):** Defines roles, responsibilities, and escalation paths.
- **Response Time Targets:**
  - Detection within 15 minutes.
  - Containment within 1 hour.
  - Recovery within 24 hours for critical systems.
- **Escalation Protocols:**
  - Level 1: Local IT team.
  - Level 2: SOC escalation.
  - Level 3: Group CISO and Board notification.
- **Post-Incident Review:** Root cause analysis and lessons learned documented within 7 days.

5. Penetration Testing & Vulnerability Management

- **Red-Team Exercises:** Annual penetration tests simulating real-world attacks.
- **Vulnerability Scans:** Conducted quarterly across all systems.
- **Patch Management:**
  - Critical patches applied within 48 hours.
  - High-risk patches within 7 days.
  - Medium-risk patches within 30 days.
- **Reporting:** Monthly vulnerability reports submitted to the Risk Committee.

6. Third-Party & Supply Chain Risk

- **Vendor Due Diligence:** All vendors must comply with Barclays' security standards.
- **Contractual Obligations:** Security clauses embedded in all contracts.
- **Continuous Monitoring:** Vendors subject to ongoing risk assessments.
- **Cloud Providers:** Must meet Barclays' encryption and resilience standards.

7. AI & Emerging Technology Risks

- **AI Risk Management:** Barclays monitors AI-driven fraud and cyber threats.
- **Ethical AI Use:** AI systems must comply with Barclays' Code of Conduct.
- **Bias & Transparency:** AI models reviewed for bias and explainability.
- **Emerging Threats:** Policies updated annually to address quantum computing, deepfakes, and advanced persistent threats (APTs).

8. Employee Awareness & Training

- **Mandatory Training:** Annual cybersecurity awareness training for all employees.
- **Phishing Simulations:** Quarterly exercises to test employee resilience.
- **Role-Specific Training:** Enhanced training for privileged users and developers.
- **Reporting Culture:** Employees encouraged to report suspicious activity without fear of reprisal.

9. Compliance & Regulation

- **GDPR & UK Data Protection Act:** Full compliance with data protection requirements.
- **FCA/PRA Operational Resilience:** Cybersecurity integrated into resilience frameworks.
- **NIS2 Directive (EU):** Applies to European operations.
- **ISO 27001:** Barclays aligns with international information security standards.

10. Metrics & KPIs

- **Incident Response Time:** Average time to detect and contain incidents.
- **Patch Compliance Rate:** Percentage of systems patched within required timelines.
- **Phishing Resilience Score:** Percentage of employees passing phishing simulations.
- **Vendor Compliance Rate:** Percentage of vendors meeting Barclays' security standards.

11. Enforcement

- **Violations:** May result in disciplinary action, up to termination.
- **Audit:** Internal Audit reviews compliance annually.
- **Continuous Improvement:** Policy updated annually to reflect new threats.

Policy 3: IT Operations & Resilience Policy

1. Purpose & Scope

This policy defines Barclays' approach to ensuring IT operational resilience, business continuity, and disaster recovery. It applies to:

- All Barclays IT systems, applications, and infrastructure globally.
- All employees, contractors, and third-party service providers.
- All business units and subsidiaries, including joint ventures.

The objective is to ensure that Barclays can withstand, respond to, and recover from operational disruptions while maintaining critical services for customers, regulators, and stakeholders.

2. Governance & Accountability

- **Board Oversight:** The Risk Committee and Audit Committee oversee resilience planning.
- **Chief Operating Officer (COO):** Accountable for IT operations and resilience strategy.
- **Resilience Steering Committee:** Cross-functional body responsible for resilience testing and reporting.
- **Internal Audit:** Conducts annual reviews of resilience controls and recovery capabilities.

3. Business Continuity Management (BCM)

- **Critical Services Identification:** Barclays identifies critical services (payments, trading, customer access) and maps dependencies.
- **Recovery Objectives:**
  - Recovery Time Objective (RTO): ≤ 4 hours for critical services.
  - Recovery Point Objective (RPO): ≤ 15 minutes for critical data.
- **Continuity Plans:** Each business unit maintains documented continuity plans.
- **Testing:** Annual continuity exercises across all regions.

4. Disaster Recovery (DR)

- **Data Centres:** Barclays operates redundant data centres with geographic separation.
- **Cloud Resilience:** Hybrid cloud adoption with multi-region failover.
- **Backup Strategy:**
  - Daily backups for critical systems.
  - Weekly full backups retained for 12 months.
  - Offsite storage for disaster scenarios.
- **DR Drills:** Semi-annual disaster recovery drills simulating cyberattacks, natural disasters, and system failures.

5. Change Management

- **Approval Process:** All IT changes require documented approval and rollback plans.
- **Segregation of Duties:** Developers cannot deploy directly to production.
- **Audit Trails:** All changes logged and retained for 7 years.
- **Emergency Changes:** Allowed only with CISO/COO approval, documented post-implementation.

6. Cloud Security & Resilience

- **Cloud Adoption:** Barclays uses hybrid cloud with strict identity and access management.
- **Resilience Standards:** Cloud providers must meet Barclays' encryption and failover requirements.
- **Monitoring:** Continuous monitoring of cloud workloads.
- **Exit Strategy:** Documented plans for cloud provider exit or migration.

7. Resilience Testing

- **Scenario Testing:** Barclays conducts resilience tests for cyberattacks, pandemics, and geopolitical disruptions.
- **Tabletop Exercises:** Quarterly exercises with senior management.
- **Live Simulations:** Annual live simulations involving IT, operations, and business units.
- **Metrics:** Test results documented and reported to the Board.

8. Operational KPIs

- **System Uptime:** ≥ 99.95% for critical systems.
- **Incident Response Time:** ≤ 1 hour for critical incidents.
- **Patch Compliance Rate:** ≥ 95% within required timelines.
- **Resilience Test Pass Rate:** ≥ 90% across all scenarios.

9. Third-Party & Outsourcing Risk

- **Vendor Resilience Standards:** Vendors must demonstrate resilience capabilities.
- **Contractual Obligations:** SLAs must include resilience metrics.
- **Monitoring:** Continuous vendor risk assessments.
- **Exit Planning:** Documented contingency plans for vendor failure.

10. Compliance & Regulation

- **FCA/PRA Operational Resilience Framework:** Full compliance with UK regulatory requirements.
- **GDPR & Data Protection Act:** Ensures data recovery aligns with privacy obligations.
- **Basel Committee Principles:** Alignment with international banking resilience standards.
- **NIS2 Directive (EU):** Applies to European operations.

11. Continuous Improvement

- **Annual Review:** Policy updated annually to reflect new threats and regulatory changes.
- **Lessons Learned:** Post-incident reviews feed into resilience improvements.
- **Innovation:** Adoption of emerging technologies (AI, automation) to enhance resilience.

Policy 4: Data Privacy & Compliance Policy

1. Purpose & Scope

This policy establishes Barclays' approach to protecting customer and employee personal data, ensuring compliance with global privacy regulations, and maintaining trust with stakeholders. It applies to:

- All Barclays employees, contractors, and third-party vendors.
- All systems, applications, and processes handling personal or sensitive data.
- All business units and subsidiaries globally.

The objective is to ensure lawful, fair, and transparent processing of personal data, aligned with GDPR, UK Data Protection Act, and other applicable regulations.

2. Governance & Accountability

- **Board Oversight:** The Audit Committee and Risk Committee oversee data privacy risks.
- **Data Protection Officer (DPO):** Accountable for compliance with privacy regulations, reporting to the Group Risk Committee.
- **Business Unit Responsibility:** Each unit must appoint a Privacy Champion to oversee local compliance.
- **Internal Audit:** Conducts annual reviews of privacy controls and compliance.

3. Data Collection & Processing

- **Lawful Basis:** Data collected only under lawful bases (consent, contract, legal obligation, legitimate interest).
- **Transparency:** Customers informed via privacy notices about data usage.
- **Purpose Limitation:** Data processed only for specified, explicit, and legitimate purposes.
- **Data Minimization:** Only necessary data collected and retained.

4. Data Subject Rights

Barclays ensures compliance with GDPR and UK Data Protection Act by enabling:

- **Right of Access:** Customers can request copies of their personal data.
- **Right to Rectification:** Inaccurate data corrected promptly.
- **Right to Erasure ("Right to be Forgotten"):** Data deleted upon valid request.
- **Right to Restrict Processing:** Customers can limit how their data is used.
- **Right to Data Portability:** Customers can request transfer of their data to another provider.
- **Right to Object:** Customers can object to processing for marketing or profiling.

5. Data Security & Protection

- **Encryption:** All personal data encrypted at rest (AES-256) and in transit (TLS 1.3).
- **Access Controls:** Role-based access with MFA.
- **Audit Logging:** Immutable logs retained for 7 years.
- **Data Masking:** Sensitive data masked in non-production environments.
- **Anonymization:** Personal data anonymized when used for analytics.

6. Data Retention & Disposal

- **Retention Periods:**
  - Customer financial records: minimum 7 years.
  - HR records: minimum 6 years post-employment.
  - Marketing data: maximum 2 years unless renewed consent.
- **Secure Disposal:** Data deleted using industry-standard secure wipe methods.
- **Archiving:** Archived data encrypted and access restricted.

7. Third-Party & Vendor Compliance

- **Vendor Due Diligence:** Vendors must comply with Barclays' privacy standards.
- **Data Processing Agreements (DPAs):** Mandatory for all vendors handling personal data.
- **Monitoring:** Vendors subject to ongoing compliance reviews.
- **Cross-Border Transfers:** Data transferred outside the UK/EU only with adequate safeguards (e.g., Standard Contractual Clauses).

8. Employee Responsibilities

- **Training:** Annual mandatory privacy training.
- **Reporting:** Employees must report suspected data breaches within 1 hour.
- **Acceptable Use:** Personal data must not be stored on personal devices unless encrypted and approved.
- **Confidentiality Agreements:** All employees must sign confidentiality agreements.

9. Breach Management

- **Incident Response:** Data breaches reported to the DPO within 24 hours.
- **Regulatory Notification:** ICO and other regulators notified within 72 hours if required.
- **Customer Notification:** Customers informed promptly if their data is impacted.
- **Post-Incident Review:** Root cause analysis conducted within 7 days.

10. Compliance & Regulation

- **GDPR:** Full compliance with EU General Data Protection Regulation.
- **UK Data Protection Act 2018:** Compliance across UK operations.
- **FCA/PRA Requirements:** Privacy integrated into operational resilience frameworks.
- **NIS2 Directive (EU):** Applies to European operations.
- **ISO 27701:** Alignment with international privacy management standards.

11. Metrics & KPIs

- **Data Breach Response Time:** ≤ 72 hours for regulatory notification.
- **Training Completion Rate:** ≥ 95% of employees annually.
- **Vendor Compliance Rate:** ≥ 90% of vendors meeting Barclays' privacy standards.
- **Data Subject Request Fulfillment:** ≥ 95% requests fulfilled within statutory timelines.

12. Enforcement

- **Violations:** May result in disciplinary action, up to termination.
- **Audit:** Internal Audit reviews compliance annually.
- **Continuous Improvement:** Policy updated annually to reflect new regulations and threats.

Policy 5: Employee & Insider Risk Policy

1. Purpose & Scope

This policy establishes Barclays' approach to managing insider risk, ensuring employees and contractors act responsibly, and protecting the organization against internal threats. It applies to:

- All Barclays employees, contractors, and third-party vendors with system or data access.
- All business units and subsidiaries globally.
- All systems, applications, and processes where insider activity could impact confidentiality, integrity, or availability.

The objective is to mitigate risks arising from human error, negligence, or malicious insider activity while fostering a culture of accountability and trust.

2. Governance & Accountability

- **Board Oversight:** The Risk Committee and Audit Committee oversee insider risk management.
- **Chief Human Resources Officer (CHRO):** Accountable for employee conduct and insider risk programs.
- **Chief Information Security Officer (CISO):** Accountable for monitoring insider activity and reporting to the Group Risk Committee.
- **Insider Risk Management Team:** Cross-functional body including HR, Legal, Compliance, and IT Security.
- **Internal Audit:** Conducts annual reviews of insider risk controls.

3. Employee Onboarding & Screening

- **Background Checks:** Mandatory for all new hires, including criminal, financial, and reference checks.
- **Access Provisioning:** Access granted only after completion of onboarding and training.
- **Confidentiality Agreements:** All employees must sign confidentiality agreements before system access.
- **Role-Based Access:** Access aligned with job responsibilities, reviewed quarterly.

4. Acceptable Use Policy

- **System Usage:** Employees must use Barclays systems only for authorized business purposes.
- **Personal Devices (BYOD):** Allowed only under Mobile Device Management (MDM) controls.
- **Email & Internet Use:** Restricted to professional activities; monitoring in place.
- **Prohibited Activities:** Unauthorized downloads, use of unapproved cloud services, and data exfiltration.

5. Monitoring & Detection

- **User Activity Monitoring:** High-risk activities flagged for review (e.g., mass downloads, unusual access times).
- **Behavioral Analytics:** AI-driven monitoring of anomalous employee behavior.
- **Privileged User Monitoring:** Enhanced monitoring for administrators and developers.
- **Audit Logging:** Immutable logs retained for 7 years.

6. Training & Awareness

- **Mandatory Training:** Annual insider risk and cybersecurity awareness training.
- **Phishing Simulations:** Quarterly exercises to test employee resilience.
- **Role-Specific Training:** Enhanced training for privileged users and developers.
- **Culture of Responsibility:** Employees encouraged to report suspicious activity without fear of reprisal.

7. Incident Response & Escalation

- **Insider Threat Response Plan:** Defines roles, responsibilities, and escalation paths.
- **Escalation Protocols:**
  - Level 1: Local HR/IT team.
  - Level 2: Insider Risk Management Team.
  - Level 3: Group CISO and Board notification.
- **Post-Incident Review:** Root cause analysis and lessons learned documented within 7 days.
- **Disciplinary Action:** May include suspension, termination, or legal proceedings.

8. Whistleblowing & Reporting

- **Whistleblowing Hotline:** Anonymous reporting channel available globally.
- **Protection:** Whistleblowers protected against retaliation.
- **Investigation:** All reports investigated promptly by HR and Compliance.
- **Transparency:** Outcomes reported to the Audit Committee.

9. Third-Party & Contractor Risk

- **Vendor Screening:** Contractors subject to background checks and access restrictions.
- **Access Controls:** Contractors granted time-bound, role-based access.
- **Monitoring:** Contractor activity monitored continuously.
- **Exit Procedures:** Contractor access revoked immediately upon contract termination.

10. Compliance & Regulation

- **GDPR & UK Data Protection Act:** Insider monitoring aligned with privacy obligations.
- **FCA/PRA Requirements:** Insider risk integrated into operational resilience frameworks.
- **Employment Law:** Compliance with local labor laws across jurisdictions.
- **ISO 27001:** Alignment with international information security standards.

11. Metrics & KPIs

- **Training Completion Rate:** ≥ 95% of employees annually.
- **Incident Response Time:** ≤ 24 hours for insider incidents.
- **Privileged Access Review Rate:** 100% quarterly.
- **Whistleblowing Case Resolution:** ≥ 90% resolved within statutory timelines.

12. Enforcement

- **Violations:** May result in disciplinary action, up to termination.
- **Audit:** Internal Audit reviews compliance annually.
- **Continuous Improvement:** Policy updated annually to reflect new threats and regulatory changes.

Policy 6: Emerging Technology & AI Policy

1. Purpose & Scope

This policy establishes Barclays' approach to adopting, governing, and securing emerging technologies, with a particular focus on Artificial Intelligence (AI). It applies to:

- All Barclays employees, contractors, and third-party vendors involved in technology development, deployment, or oversight.
- All AI systems, machine learning models, and emerging technologies (cloud, blockchain, quantum computing, etc.) used within Barclays.
- All business units and subsidiaries globally.

The objective is to ensure that emerging technologies are deployed responsibly, ethically, securely, and in compliance with regulatory requirements.

2. Governance & Accountability

- **Board Oversight:** The Technology Committee and Risk Committee oversee emerging technology adoption.
- **Chief Technology Officer (CTO):** Accountable for emerging technology strategy.
- **Chief Information Security Officer (CISO):** Accountable for security risks associated with new technologies.
- **AI Governance Council:** Cross-functional body including Risk, Compliance, Legal, and Technology teams.
- **Internal Audit:** Conducts annual reviews of AI and emerging technology governance.

3. AI Governance Framework

- **Ethical Principles:** AI systems must be fair, transparent, accountable, and aligned with Barclays' Code of Conduct.
- **Bias Monitoring:** AI models tested regularly for bias and discriminatory outcomes.
- **Explainability:** AI decisions must be explainable to regulators, customers, and internal stakeholders.
- **Human Oversight:** Critical AI decisions (e.g., credit scoring, fraud detection) require human validation.
- **Lifecycle Management:** AI models documented, version-controlled, and subject to periodic review.

4. Security & Risk Management

- **AI-Specific Threats:** Monitoring for adversarial attacks, model poisoning, and deepfake fraud.
- **Data Security:** Training data must be anonymized, encrypted, and sourced responsibly.
- **Access Controls:** Role-based access to AI models and datasets.
- **Incident Response:** AI-related incidents escalated through Barclays' SOC and IRP.
- **Third-Party Risk:** Vendors providing AI solutions must comply with Barclays' security standards.

5. Emerging Technology Adoption

- **Cloud Computing:** Hybrid cloud adoption with strict identity and access management.
- **Blockchain:** Used only for approved financial services with regulatory compliance.
- **Quantum Computing:** Research monitored for potential cryptographic risks.
- **Automation & Robotics:** Deployed with safeguards to prevent operational disruption.
- **Innovation Labs:** Emerging technologies tested in controlled environments before production deployment.

6. Regulatory Compliance

- **GDPR & UK Data Protection Act:** AI systems must comply with data protection requirements.
- **FCA/PRA Requirements:** Emerging technologies integrated into operational resilience frameworks.
- **EU AI Act:** Compliance with European AI regulations.
- **ISO/IEC 23894:** Alignment with international AI risk management standards.

7. Employee Awareness & Training

- **Mandatory Training:** Annual training on AI ethics and emerging technology risks.
- **Specialist Training:** Advanced training for developers, data scientists, and risk managers.
- **Awareness Campaigns:** Regular updates on emerging threats (e.g., deepfakes, quantum risks).
- **Reporting Culture:** Employees encouraged to report concerns about AI or emerging technology misuse.

8. Metrics & KPIs

- **AI Model Review Rate:** ≥ 95% of models reviewed annually.
- **Bias Detection Rate:** ≥ 90% of models tested for bias.
- **Vendor Compliance Rate:** ≥ 90% of vendors meeting Barclays' AI standards.
- **Training Completion Rate:** ≥ 95% of employees annually.

9. Continuous Improvement

- **Annual Review:** Policy updated annually to reflect new technologies and regulatory changes.
- **Lessons Learned:** Post-incident reviews feed into AI governance improvements.
- **Innovation:** Adoption of emerging technologies aligned with Barclays' strategic objectives.

10. Enforcement

- **Violations:** May result in disciplinary action, up to termination.
- **Audit:** Internal Audit reviews compliance annually.
- **Continuous Improvement:** Policy updated annually to reflect new threats and opportunities.

Policy 7: Audit & Continuous Improvement Policy

1. Purpose & Scope

This policy establishes Barclays' approach to auditing IT and cybersecurity controls, monitoring compliance, and driving continuous improvement across technology and risk management functions. It applies to:

- All Barclays IT systems, applications, and infrastructure globally.
- All employees, contractors, and third-party vendors.
- All business units and subsidiaries, including joint ventures.

The objective is to ensure that IT and cybersecurity practices remain effective, resilient, and aligned with regulatory requirements and industry best practices.

2. Governance & Accountability

- **Board Oversight:** The Audit Committee and Risk Committee oversee IT audit and continuous improvement activities.
- **Chief Audit Executive (CAE):** Accountable for internal audit strategy and reporting.
- **Chief Information Security Officer (CISO):** Accountable for cybersecurity audit readiness and remediation.
- **Continuous Improvement Council:** Cross-functional body including Audit, Risk, Compliance, and Technology teams.
- **External Assurance:** Independent external auditors engaged annually to validate IT and cyber resilience.

3. Audit Framework

- **Internal Audit:** Annual audits of IT operations, cybersecurity, and data privacy controls.
- **Risk-Based Approach:** Audit priorities determined by risk assessments and regulatory requirements.
- **Control Testing:** Key controls tested for design and operating effectiveness.
- **Audit Trails:** All IT changes, incidents, and access logs retained for 7 years.
- **Reporting:** Audit findings reported to the Audit Committee and Board.

4. Continuous Monitoring

- **Key Risk Indicators (KRIs):** Defined for cyber incidents, system downtime, and vendor compliance.
- **Key Performance Indicators (KPIs):**
  - Incident response time.
  - Patch compliance rate.
  - Training completion rate.
  - Vendor compliance rate.
- **Dashboards:** Real-time dashboards provided to senior management.
- **Automated Alerts:** SOC generates alerts for deviations from resilience thresholds.

5. Continuous Improvement Cycle

- **Plan:** Identify risks, set objectives, and define improvement initiatives.
- **Do:** Implement controls, training, and technology enhancements.
- **Check:** Audit and monitor performance against KPIs.
- **Act:** Remediate gaps, update policies, and enhance resilience.
- **Annual Review:** Policies updated annually to reflect new threats and regulatory changes.

6. Incident & Breach Reviews

- **Post-Incident Analysis:** Root cause analysis conducted within 7 days of major incidents.
- **Lessons Learned:** Incorporated into updated controls and training programs.
- **Board Reporting:** Significant incidents reported to the Board with remediation plans.
- **Regulatory Engagement:** Regulators informed of material incidents and corrective actions.

7. Vendor & Third-Party Assurance

- **Vendor Audits:** Annual audits of critical vendors' IT and cybersecurity practices.
- **Contractual Obligations:** Vendors required to provide audit rights and compliance evidence.
- **Continuous Monitoring:** Vendor compliance tracked via dashboards.
- **Exit Strategy:** Contingency plans for vendor failure or non-compliance.

8. Regulatory Compliance

- **FCA/PRA Requirements:** Audit and improvement aligned with UK operational resilience frameworks.
- **GDPR & UK Data Protection Act:** Privacy audits conducted annually.
- **NIS2 Directive (EU):** Applies to European operations.
- **ISO 27001 & ISO 27701:** Alignment with international information security and privacy standards.

9. Employee Engagement

- **Training:** Annual audit awareness training for employees.
- **Feedback Mechanisms:** Employees encouraged to suggest improvements.
- **Whistleblowing:** Anonymous reporting channels for audit or compliance concerns.
- **Recognition:** Employees recognized for contributions to continuous improvement.

10. Metrics & KPIs

- **Audit Completion Rate:** ≥ 95% of planned audits annually.
- **Remediation Closure Rate:** ≥ 90% of audit findings closed within agreed timelines.
- **Continuous Improvement Initiatives:** ≥ 80% completed annually.
- **Vendor Audit Compliance Rate:** ≥ 90% of vendors audited successfully.

11. Enforcement

- **Violations:** May result in disciplinary action, up to termination.
- **Audit:** Internal Audit reviews compliance annually.
- **Continuous Improvement:** Policy updated annually to reflect new threats and opportunities.